*Octobre 2026*

# Rapport de TP

## Déploiement et analyse de Suricata IDS sur OPNsense

**Pape Aldiouma SARR**
*L2 Cybersecurite - Module : Sécurité Réseau*

Rapport de travaux pratiques : intégration et configuration de Suricata IDS sur OPNsense, activation de règles de détection, tests d'attaque contrôles depuis Kali Linux et analyse des journaux EVE JSON.




**Republique du Senegal, Un Peuple, Un But, Une Foi**
Ministere de l'Enseignement Superieur, de la Recherche et de l'Innovation
Direction Generale de l'Enseignement Superieur Prive
**Institut Superieur de Management**
Année academique 2025-2026

# Table des matieres

Introduction..... 3
I. Configuration de Suricata IDS sur OPNsense..... 3
II. Telechargement et activation des règles de détection..... 5
III. Planification des mises a jour automatiques..... 6
IV. Verification du démarrage de Suricata..... 7
V. Tests d'attaques depuis Kali Linux..... 8
VI. Analyse des alertes dans OPNsense..... 12
VII. Tableau de validation..... 13
VIII. Mini-defi..... 14
IX. Guide de depannage..... 15
Synthèse et conclusion..... 16

# Introduction

Ce rapport documente le déploiement et le test du moteur de détection d'intrusion (IDS) Suricata, integre nativement a OPNsense. L'objectif est de configurer Suricata en mode détection pure sur l'interface LAN, d'activer des jeux de règles communautaires, puis de générer des attaques controlees depuis Kali Linux afin d'observer la reaction du système et d'analyser les journaux produits.

**Environnement :** QEMU/KVM, OPNsense (pare-feu et IDS), Debian Server (cible Apache/SSH), Debian Cliente (poste d'administration), Kali Linux (poste d'attaque). Réseau de laboratoire isole, plage 192.168.20.0/24.

# I. Configuration de Suricata IDS sur OPNsense

Depuis Debian Cliente, ouvrir Firefox et naviguer vers https://192.168.20.1. Se connecter avec les identifiants definis lors de l'installation d'OPNsense (root / mot de passe).

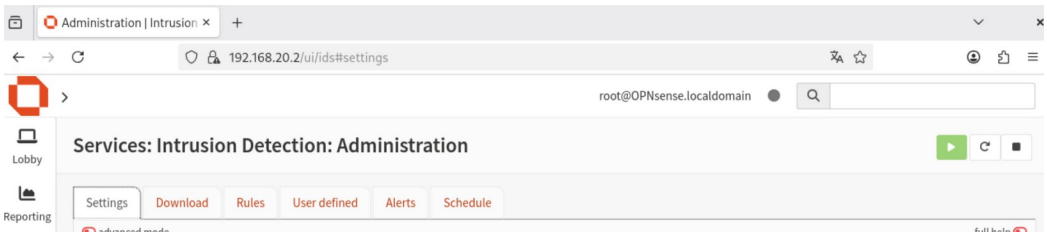
> *Suricata est déjà integre dans OPNsense : aucune installation de plugin supplémentaire n'est nécessaire.*

## 1. Acceder au module Intrusion Détection

Navigation : Services -> Intrusion Détection

La page Administration s'ouvre. Les onglets en haut de page permettent de naviguer entre les différentes fonctionnalités :

| Onglet | Rôle |
|---|---|
| Administration | Configuration générale (Settings) et statut du service |
| Download | Telecharger et activer les jeux de règles |
| Rules | Voir, rechercher et modifier les règles individuelles |
| Policy | Politiques globales de détection |
| User Defined | Créer ses propres règles Suricata |
| Alerts | Alertes générées en temps réel |
| Schedule | Planifier les mises a jour automatiques |




*Onglets du module Intrusion Détection dans OPNsense.*

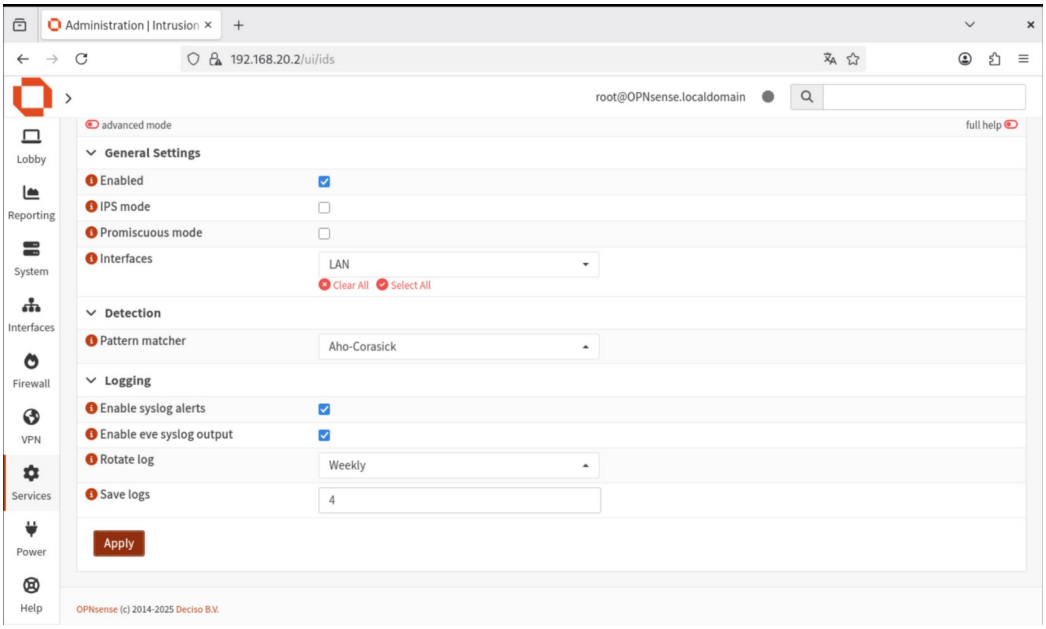
## 2. Onglet Administration : configurer les Settings

Remplir exactement les champs suivants, puis cliquer sur Apply :

| Champ | Valeur a selectionner | Explication |
|---|---|---|
| Enabled | Coche (Yes) | Active le moteur Suricata |
| Capture mode | PCAP live mode (IDS) | Copie du trafic : détection seule, aucun blocage |
| Promiscuous mode | Decoche | Non nécessaire ici (pas de VLAN sur l'interface) |
| Enable syslog alerts | Coche | Envoie les alertes dans le journal système OPNsense |
| Enable eve syslog | Coche | Active le format de log EVE JSON (structure) |
| Pattern matcher | Aho-Corasick | Compatible AMD et Intel, valeur universelle |
| Interfaces | LAN | Surveille l'interface interne (IP .20 / .50 / .99 visibles) |
| Rotate log | Weekly | Rotation hebdomadaire des fichiers de log |
| Save logs | 4 | Conserve 4 semaines d'historique |

*Pourquoi surveiller le LAN plutôt que le WAN ? Sur le WAN, le NAT masque les vraies IP internes : Suricata ne verrait que l'IP externe d'OPNsense. Sur le LAN (192.168.20.0/24), les adresses de Kali (.99), Debian Server (.20) et Debian Cliente (.50) sont visibles et exploitables dans les alertes.*

Cliquer sur Apply en bas de la page.




*Paramètres Suricata appliques dans l'onglet Administration.*

# II. Telechargement et activation des règles de détection

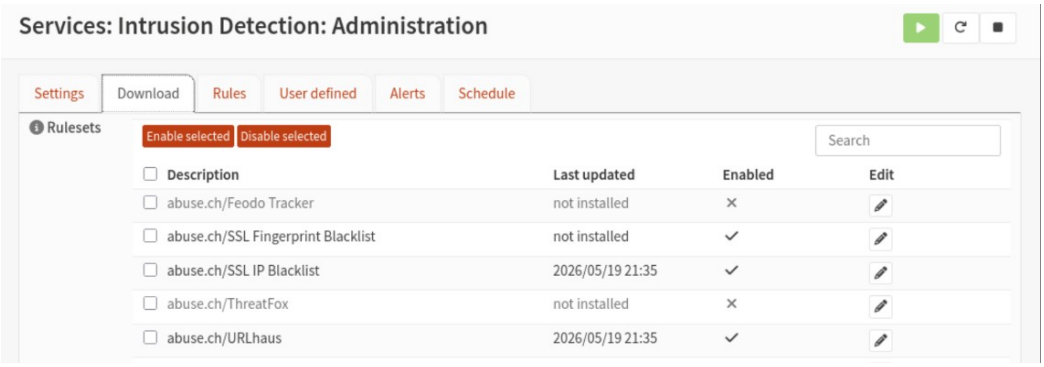
Sans règles, Suricata est actif mais aveugle. Cliquer sur l'onglet Download.

## 1. Jeux de règles disponibles

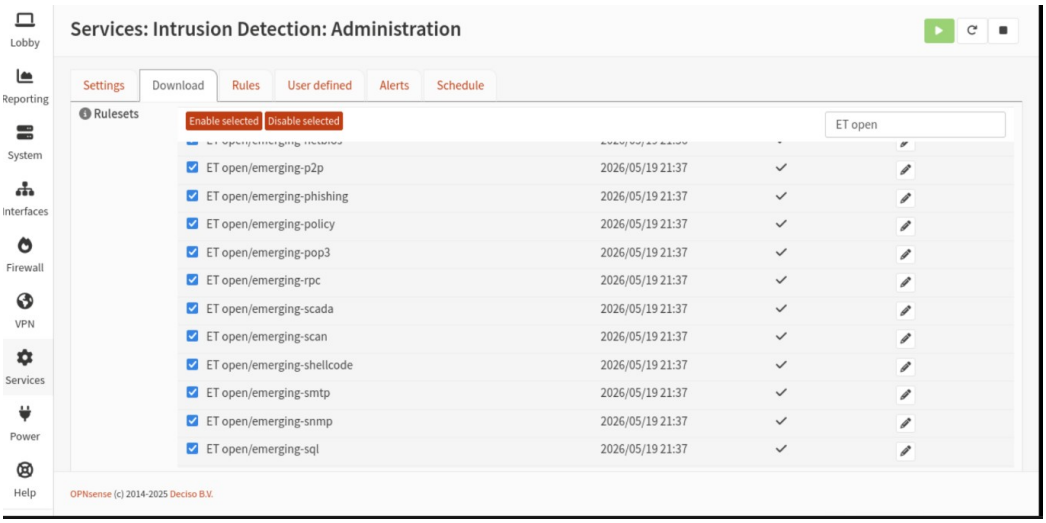
| Nom | Gratuit | Description |
|---|---|---|
| ET Open (Emerging Threats) | Oui | Règles communautaires open-source, mises a jour quotidiennes |
| Abuse.ch SSL Blacklist | Oui | Certificats SSL liés a des malwares et botnets |
| Abuse.ch URLhaus | Oui | URL connues pour distribuer des malwares |
| Abuse.ch Feodo Tracker | Oui | Serveurs C2 du trojan Feodo / Emotet / Dridex |
| ET Pro Telemetry | Oui (compte requis) | Version pro avec couverture étendue et telemetrie anonyme |

## 2. Activer et telecharger les règles

- Dans l'onglet Download, cocher les cases de : ET Open, Abuse.ch SSL Blacklist, Abuse.ch URLhaus.
- Cliquer sur Enable selected : les 3 jeux passent au statut Enabled.
- Cliquer sur Download and Update Rules.
- Attendre la fin du telechargement (environ 3 a 5 minutes selon la connexion d'OPNsense).




*Jeux de règles selectionnes et actives dans l'onglet Download.*

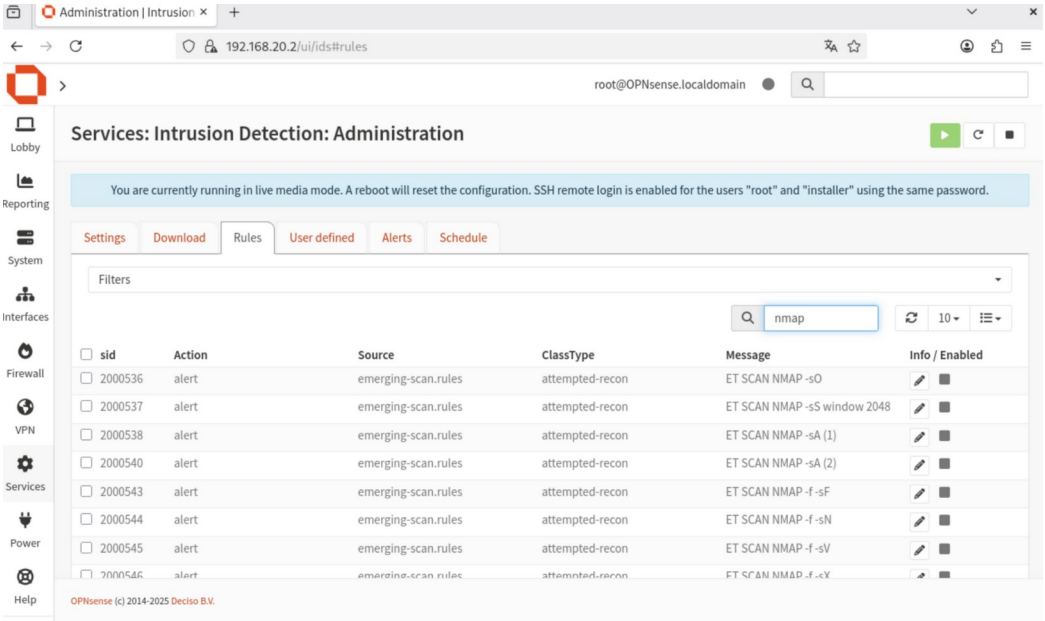



*Telechargement et mise a jour des règles en cours.*

## 3. Vérifier dans l'onglet Rules

Cliquer sur Rules puis taper "nmap" dans la barre de recherche. Résultats attendus :

- ET SCAN NMAP -sV Version Scan
- ET SCAN NMAP Scripting Engine User-Agent Detected
- ET SCAN Possible NMAP Scan



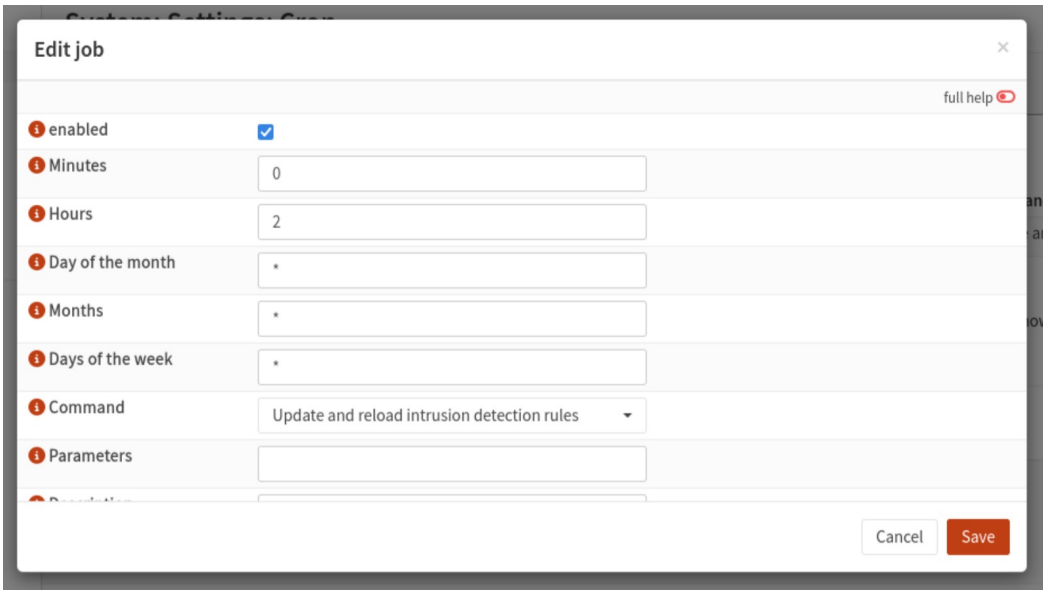

*Recherche des règles liées a Nmap dans l'onglet Rules.*

# III. Planification des mises a jour automatiques

Cliquer sur l'onglet Schedule : il redirige automatiquement vers System -> Settings -> Cron avec un formulaire pre-rempli.

| Champ | Valeur | Signification |
|---|---|---|
| Enabled | Coche | Active la tâche planifiée |
| Minutes | 0 | A la minute 0 |
| Hours | 2 | A 2h du matin |
| Day of month | * | Tous les jours du mois |
| Months | * | Tous les mois |
| Day of week | * | Tous les jours de la semaine |
| Command | (pre-rempli automatiquement) | Ne pas modifier |
| Description | Mise a jour règles IDS Suricata | Description libre |

Cliquer sur Save, puis retourner dans Services -> Intrusion Détection pour confirmer.



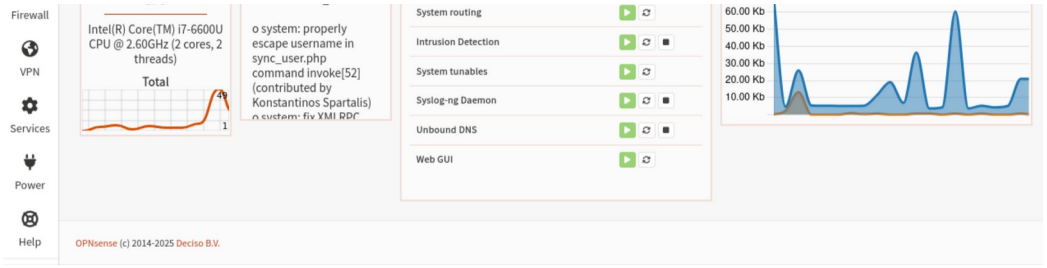

*Planification Cron de la mise a jour quotidienne des règles.*

# IV. Verification du démarrage de Suricata

## 1. Vérifier le statut du service

Depuis Debian Cliente (Firefox sur OPNsense) : Lobby -> Dashboard -> widget Services.

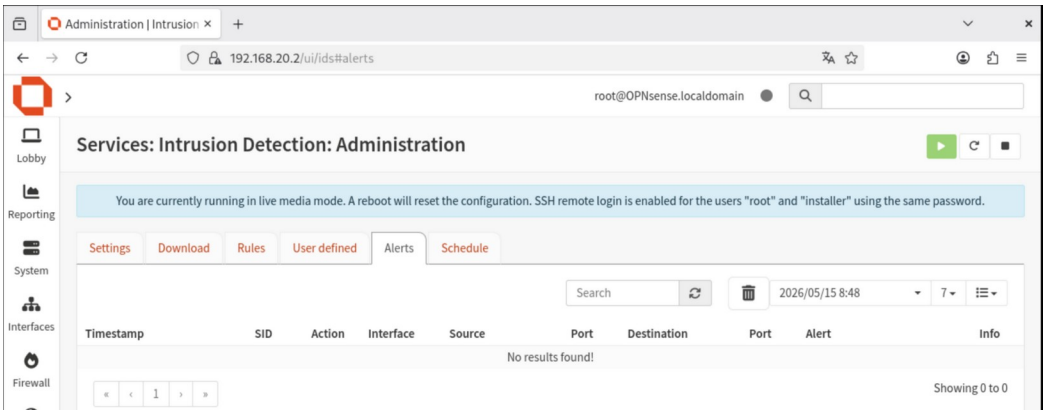
Suricata doit apparaitre avec le statut Running (vert).



*Widget Services du tableau de bord OPNsense : Suricata en cours d'exécution.*

## 2. Vérifier l'onglet Alerts

Cliquer sur Services -> Intrusion Détection -> Alerts. La page est vide, ce qui est normal a ce stade : elle se remplira lors des tests de la section suivante.




*Onglet Alerts vide avant le lancement des tests d'attaque.*

# V. Tests d'attaques depuis Kali Linux

*Rappel ethique : toutes ces attaques sont réalisées dans un réseau QEMU/KVM complètement isole, a des fins pédagogiques exclusivement. Ne jamais reproduire ces techniques sur des systèmes réels sans autorisation écrite explicite.*

Organisation de l'espace de travail : une première fenêtre sur Debian Cliente (Firefox, https://192.168.20.2, Services -> Intrusion Détection -> Alerts, rafraichie avec F5 après chaque test) et une seconde fenêtre sur Kali Linux (terminal pour lancer les attaques).

## Pourquoi les alertes peuvent ne pas s'afficher en virtualisation

Lors des tests d'attaque depuis Kali, il est possible de ne voir aucune alerte dans l'onglet Alerts d'OPNsense. Ce n'est pas une erreur de configuration : c'est un comportement attendu lie a l'architecture virtualisee.

**Explication technique :**

- Suricata est configure en mode PCAP live sur l'interface LAN d'OPNsense (vtnet1).
- Dans un environnement QEMU/KVM avec un réseau virtuel isole (lab-net en mode Isolated), le trafic entre les VM est commute directement au niveau de l'hyperviseur, via le bridge virtuel Linux (virbr1).
- Ce trafic interne (Kali vers Debian Server) peut ne pas traverser physiquement l'interface LAN d'OPNsense, mais être route directement par le bridge virtuel de l'hote Ubuntu.
- Consequence : Suricata en mode PCAP ne voit pas ce trafic, car ses paquets n'apparaissent pas sur l'interface vtnet1 d'OPNsense, ils restent dans le plan de commutation de l'hyperviseur.

**Ce que cela signifie pour le TP :**

- L'absence d'alertes ne signifie pas que Suricata est mal configure, mais que le trafic d'attaque ne transite pas par le point d'observation choisi (interface LAN d'OPNsense).
- En environnement réel, sur une infrastructure physique ou un hyperviseur correctement configure, tout le trafic passerait par OPNsense et Suricata generait bien les alertes attendues.

## Constat supplémentaire : disponibilite de la cible pendant les tests

Au-delà de la question de topologie réseau exposee ci-dessus, les sorties de commande capturees pendant les tests montrent une seconde cause, independante de Suricata, a l'absence d'alertes :

- Lors du Ping Sweep (Test 1), seule l'adresse 192.168.20.1 (OPNsense) a repondu aux requêtes ICMP sur l'ensemble du sous-réseau scanne ; Debian Server (192.168.20.20) n'a pas repondu.
- Consequence directe : les Tests 2 et 3 (nmap -sS et -sV -A, sans l'option -Pn) ont chacun conclu "Host seems down ... 0 hosts up" et n'ont donc pas envoye de paquets de scan réels vers Debian Server.
- Le Test 4 (Hydra) a renvoye "could not connect to ssh://192.168.20.20:22 - Connection refused", ce qui indique que le service SSH n'était pas joignable sur Debian Server a ce moment.
- Le Test 6 (curl, SQLi/XSS/traversee de repertoire) a renvoye "Failed to connect to 192.168.20.20 port 80 ... Could not connect to server" sur chacune des quatre requêtes, indiquant qu'Apache n'était pas non plus joignable.
- Le Test 7 a été execute depuis Kali Linux vers sa propre adresse (nc 192.168.20.99 4444, lance depuis un terminal Kali) plutôt que depuis Debian Server vers Kali comme le décrit la procédure, et s'est également solde par "Connection refused".

*Ce constat ne remet pas en cause la configuration de Suricata, documentée et vérifiée plus haut (moteur actif, règles chargees, interface LAN surveillée). Il indique plutôt que, durant cette session de tests, Debian Server n'était pas pleinement joignable (service SSH et serveur Apache non repondants, machine ne répondant pas au ping), probablement parce que les services concernes étaient arretes ou que la VM n'était pas complètement démarrée. Sans trafic réel atteignant la cible, Suricata n'avait rien a observer sur ces tests, independamment de la question du bridge virtuel. Seul le Ping Sweep (Test 1) a effectivement genere du trafic jusqu'a OPNsense.*

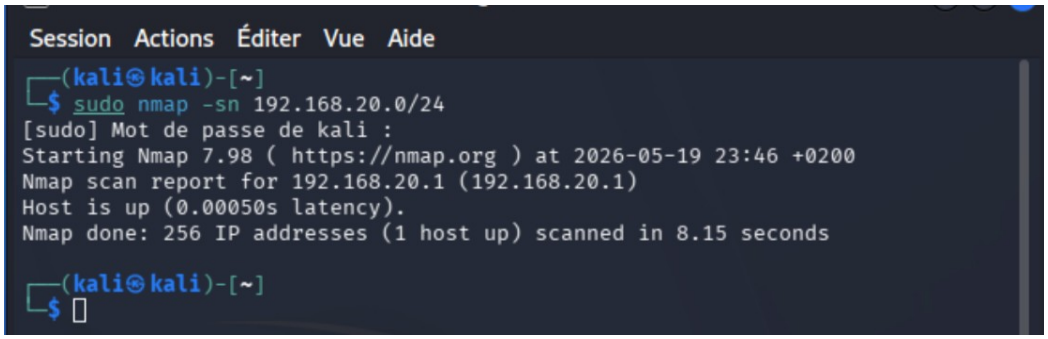
### *Test 1 : scan de reconnaissance Nmap (ping sweep)*

Objectif : identifier les machines actives sur le réseau, première étape d'une attaque réelle.

```
sudo nmap -sn 192.168.20.0/24
```

Aller sur Debian Cliente, onglet Alerts, puis F5.

| Alerte attendue | Signification |
|---|---|
| ET SCAN NMAP Ping Sweep | Balayage ICMP du réseau detecte |
| ET SCAN Potential Scan | Activité de scan generique détectée |



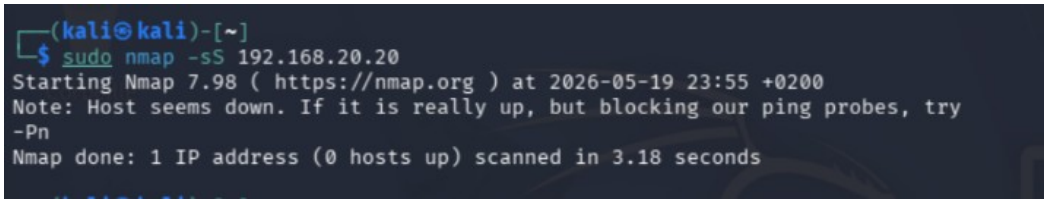

*Résultat du ping sweep Nmap depuis Kali Linux.*

### *Test 2 : scan SYN furtif*

Objectif : identifier les ports ouverts sans établir de connexion complète.

```
sudo nmap -sS 192.168.20.20
```

| Alerte attendue | Signification |
|---|---|
| ET SCAN NMAP -sS Scan | Pattern de scan SYN Nmap identifie |
| ET SCAN SYN Scan Detected | Scan SYN generique detecte |



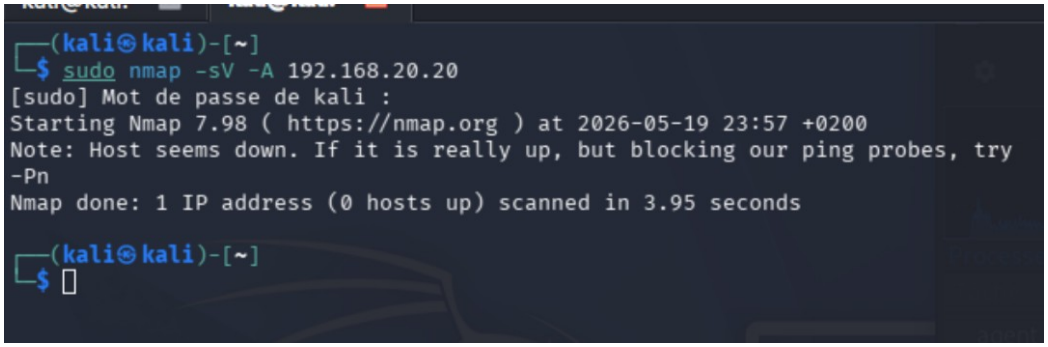

*Résultat du scan SYN furtif.*

### *Test 3 : scan de version agressif*

Objectif : identifier les versions logicielles et le système d'exploitation de la cible.

```
sudo nmap -sV -A 192.168.20.20
```

Ce scan prend plus de temps : il utilise des scripts NSE.




*Résultat du scan de version et de détection d'OS.*

### *Test 4 : brute force SSH avec Hydra*

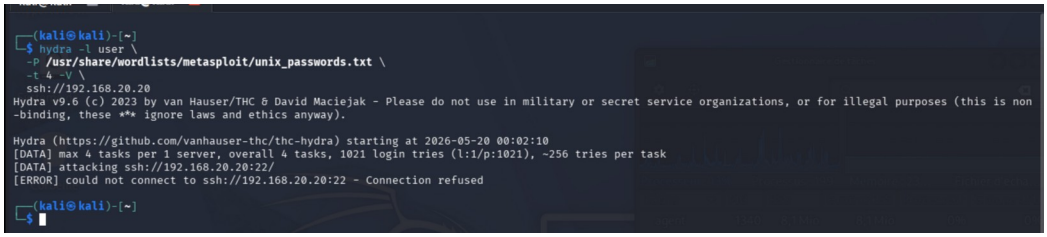
Objectif : simuler une tentative de devinette du mot de passe SSH.

Vérifier d'abord que SSH écoute sur Debian Server :

```
nc -zv 192.168.20.20 22
which hydra || sudo apt install -y hydra
```

```
hydra -l user \
  -P /usr/share/wordlists/metasploit/unix_passwords.txt \
  -t 4 -V \
  ssh://192.168.20.20
```

| Alerte attendue | Signification |
|---|---|
| ET SCAN Potential SSH Scan OUTBOUND | Tentatives SSH repetees detectees |
| ET BRUTE SSH brute force attempt | Attaque brute force SSH caracterisee |




*Tentatives de connexion SSH par force brute via Hydra.*

### *Test 5 : scan de vulnérabilités web (Nikto)*

Objectif : identifier des vulnérabilités courantes sur le serveur Apache.

```
sudo apt install -y nikto
nikto -h http://192.168.20.20
```

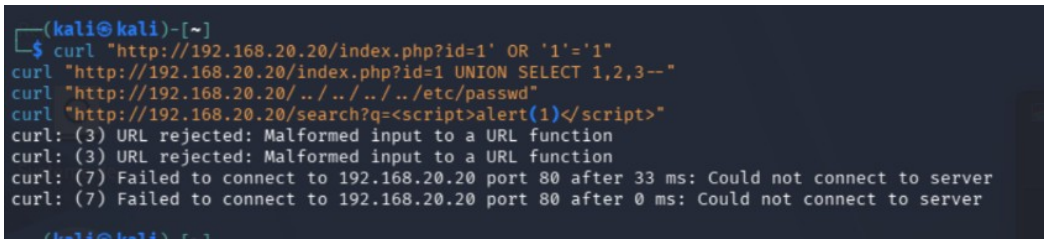
| Alerte attendue | Signification |
|---|---|
| ET WEB_CLIENT Nikto Scanner User-Agent Detected | User-Agent de Nikto identifie dans les requêtes HTTP |
| ET WEB_SERVER Possible SQL Injection Attempt | Requêtes de type SQL générées par Nikto |

### *Test 6 : injections SQL, XSS et parcours de repertoire*

Objectif : simuler des requêtes HTTP malveillantes ciblant Apache sur Debian Server.

```
curl "http://192.168.20.20/index.php?id=1' OR '1'='1"
curl "http://192.168.20.20/index.php?id=1 UNION SELECT 1,2,3--"
curl "http://192.168.20.20/../../../../etc/passwd"
curl "http://192.168.20.20/search?q=%3Cscript%3Ealert(1)%3C/script%3E"
```

| Alerte attendue | Type d'attaque |
|---|---|
| ET WEB_SERVER Possible SQL Injection Attempt | Injection SQL dans un paramètre d'URL |
| ET WEB_SERVER Directory Traversal Attempt | Traversee de repertoire vers /etc/passwd |
| ET WEB_SERVER Cross-Site Scripting Attempt | Injection de script JavaScript dans un paramètre d'URL |




*Requêtes HTTP malveillantes (SQLi, XSS, traversee de repertoire) envoyées vers Apache.*

### *Test 7 : simulation de trafic C2 (Command & Control)*

Objectif : simuler une machine compromise (Debian Server) contactant un serveur C2 (Kali).

Depuis Kali Linux, terminal 1, démarrer l'ecouteur :

```
nc -lvp 4444
```

Depuis Kali, terminal 2, ouvrir une session SSH sur Debian Server :

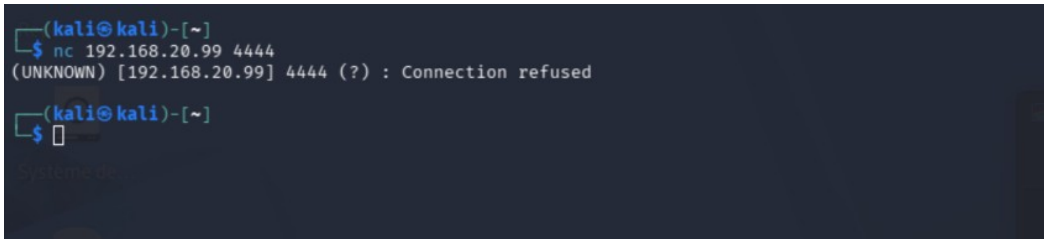
```
ssh user@192.168.20.20
```

Sur Debian Server, simuler la connexion vers le serveur C2 (Kali) :

```
nc 192.168.20.99 4444
```

Taper quelques messages, laisser 30 secondes puis Ctrl+C.

| Alerte attendue | Signification |
|---|---|
| ET POLICY Suspicious Inbound to Port 4444 | Port 4444 souvent utilise par Metasploit et autres C2 |
| ET TROJAN Possible C2 Connection | Connexion correspondant a un pattern de trojan C2 |

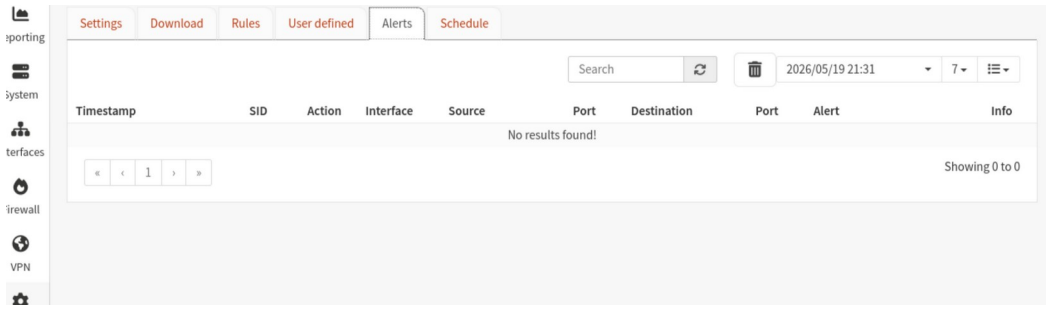



*Session netcat simulant une connexion vers un serveur de commande et contrôle.*

# VI. Analyse des alertes dans OPNsense

## 1. Lire l'onglet Alerts (depuis Debian Cliente)

Depuis Debian Cliente, Firefox, https://192.168.20.2, Services -> Intrusion Détection -> Alerts : aucune alerte n'est visible a ce niveau, pour les raisons techniques expliquees a la section V.




*Onglet Alerts d'OPNsense après l'ensemble des tests.*

## 2. Lire les logs EVE JSON

Depuis OPNsense : System -> Diagnostics -> Execute command.

```
tail -20 /var/log/suricata/eve.json | grep '"event_type":"alert"'
grep '192.168.20.99' /var/log/suricata/eve.json | grep '"event_type":"alert"' | tail -10
tail -1 /var/log/suricata/eve.json | python3 -m json.tool
```

Structure d'une alerte EVE JSON, commentee :

```
{
  "timestamp": "2026-01-15T14:23:05.123456+0000",
  "event_type": "alert",
  "src_ip": "192.168.20.99",      // Kali Linux (attaquant)
  "src_port": 54321,
  "dest_ip": "192.168.20.20",     // Debian Server (cible)
  "dest_port": 22,                 // port SSH
  "proto": "TCP",
  "alert": {
    "action": "allowed",          // IDS : le trafic n'est pas bloque
    "signature_id": 2001219,       // SID de la règle déclenchée
    "signature": "ET SCAN Potential SSH Scan OUTBOUND",
    "category": "Attempted Information Leak",
    "severity": 2                  // gravite : 2 = majeur
  }
}
```

*"action": "allowed" confirme le mode IDS. En mode IPS (Netmap ou Divert), cette valeur deviendrait "blocked" ou "drop" et le paquet serait réellement arrete avant d'atteindre la cible.*

# VII. Tableau de validation

Synthèse des tests realises. Aucune alerte n'a été visible dans l'onglet Alerts d'OPNsense sur l'ensemble des tests, pour deux raisons cumulees detaillees a la section V : le trafic entre Kali et Debian Server transite par le bridge virtuel de l'hyperviseur sans passer par l'interface LAN surveillée, et Debian Server n'était pas pleinement joignable (ICMP, SSH et HTTP) durant une partie de la session de tests.

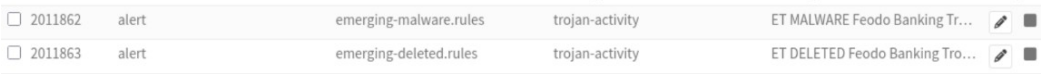
| Test | Commande (Kali) | IP source | Port dest. | Alerte observee |
|---|---|---|---|---|
| Ping Sweep | nmap -sn 192.168.20.0/24 | 192.168.20.99 | - | Aucune ; seul OPNsense (.1) a repondu |
| SYN Scan | nmap -sS 192.168.20.20 | 192.168.20.99 | variable | Aucune ; cible signalée hors ligne (0 host up) |
| Scan de version | nmap -sV -A 192.168.20.20 | 192.168.20.99 | variable | Aucune ; cible signalée hors ligne (0 host up) |
| Brute force SSH | hydra ... ssh://192.168.20.20 | 192.168.20.99 | 22 | Aucune ; SSH Connection refused |
| Nikto | nikto -h http://192.168.20.20 | 192.168.20.99 | 80 | Aucune ; pas de capture disponible pour confirmer la joignabilite |
| Injection SQL / XSS / traversee | curl ...?id=1' OR '1'='1 (et autres) | 192.168.20.99 | 80 | Aucune ; HTTP Could not connect to server |
| Trafic C2 | nc 192.168.20.99 4444 (execute depuis Kali) | 192.168.20.99 | 4444 | Aucune ; Connection refused, test non conforme a la procédure (voir section V) |

# VIII. Mini-defi

## Defi 1 : activer les règles Feodo Tracker (Emotet / Dridex)

Le responsable SOC demande d'ajouter la détection des serveurs C2 du trojan bancaire Feodo :

- Services -> Intrusion Détection -> Download
- Rechercher "Feodo" dans la liste
- Cocher la case, puis Enable selected, puis Download and Update Rules
- Vérifier dans l'onglet Rules (recherche "feodo") que les règles sont bien presentes




*Jeu de règles Feodo Tracker active dans l'onglet Download.*

## Defi 2 : documenter une règle Suricata

Cette partie du defi n'a pas pu être complétée en l'état : comme expose a la section V, aucune alerte n'a été générée dans l'onglet Alerts en raison du contournement du point d'observation (le trafic inter-VM ne traverse pas l'interface LAN surveillée par Suricata

dans cette topologie virtualisee). Il n'y avait donc pas d'alerte concrete a partir de laquelle retrouver une règle par son SID et documenter ses champs.

Pour compléter cet exercice, deux approches sont possibles : forcer le trafic a traverser l'interface LAN d'OPNsense (par exemple en placant Suricata en coupure sur le lien physique plutôt que sur un bridge interne a l'hyperviseur), ou analyser directement une règle depuis l'onglet Rules (par exemple la règle ET SCAN Potential SSH Scan OUTBOUND) sans attendre qu'elle se declenche, afin d'en documenter la structure a titre d'exemple.

# IX. Guide de depannage

| Problème observe | Cause probable | Solution |
|---|---|---|
| kvm-ok : cannot be used | VT-x/AMD-V desactive dans le BIOS | Redémarrer, activer dans le BIOS (F2/F10/Suppr) |
| OPNsense sans IP WAN | NIC 1 non connectée au réseau default | Vérifier dans Virt-Manager, VM opnsense-lab, NIC 1 |
| VM ne se pinguent pas | IP mal configurée ou réseau lab-net incorrect | ip addr show sur chaque VM, vérifier virsh net-list |
| apt update echoue sur Debian | Pas de DNS, OPNsense pas demarre | Démarrer OPNsense en premier, vérifier la passerelle 192.168.20.1 |
| Telechargement des règles echoue | OPNsense sans accès Internet | Console OPNsense : ping 8.8.8.8, vérifier la NIC WAN |
| Aucune alerte dans Alerts | Interface LAN non sélectionnée ou Suricata arrete | Vérifier Settings, Interface = LAN, cliquer sur Apply |
| Apache ne répond pas | Service arrete sur Debian Server | systemctl start apache2 sur Debian Server |
| SSH refuse | Service arrete ou pare-feu actif | systemctl start ssh ; vérifier ufw status sur Debian Server |
| Firefox n'affiche pas OPNsense | IP Cliente mal configurée ou OPNsense arrete | ip addr sur Debian Cliente, ping 192.168.20.1 |

## Commandes de diagnostic rapide

### Sur l'hote Ubuntu :

```
virsh list --all              # état de toutes les VM
virsh net-list --all          # réseaux virtuels (default + lab-net)
virsh domiflist opnsense-lab  # vérifier les 2 NIC d'OPNsense
```

### Sur OPNsense :

```
ifconfig                                # interfaces et IP
ping 8.8.8.8                            # test Internet
tail -20 /var/log/suricata/eve.json     # dernières alertes JSON
```

### Sur Debian Server :

```
ip addr show                   # IP configurée
```

```
systemctl status apache2 ssh   # services actifs
```

**Sur Kali Linux :**

```
ip addr show && ip route show   # IP .99 et route par defaut via .1
curl -v http://192.168.20.20    # Apache de Debian Server accessible ?
```

# Synthèse et conclusion

## Ce qui a été mis en place

- QEMU/KVM sur Ubuntu, avec un réseau virtuel isole lab-net (192.168.20.0/24).
- OPNsense (192.168.20.1) : pare-feu et Suricata IDS en mode PCAP live (détection seule).
- Debian Server (192.168.20.20) : cible avec Apache et SSH, attaquee depuis Kali.
- Debian Cliente (192.168.20.50) : poste d'observation avec GNOME et Firefox sur la WebGUI d'OPNsense.
- Kali Linux (192.168.20.99) : poste d'attaque avec Nmap, Hydra, Nikto, curl, netcat.
- Règles ET Open et Abuse.ch telechargees, activees, avec mise a jour automatique configurée a 2h du matin.

## Questions de compréhension

### 1. Pourquoi OPNsense surveille-t-il l'interface LAN plutôt que le WAN ?

OPNsense surveille l'interface LAN plutôt que le WAN pour des raisons de fiabilite de supervision : le but est de vérifier si le pare-feu lui-même et le réseau interne sont fonctionnels, et pas seulement si Internet est joignable. Sur le WAN, le NAT masque de plus les adresses internes réelles.

### 2. Quelle est la différence concrete entre IDS (PCAP live) et IPS (Netmap/Divert) ?

Un IDS observe le trafic, le journalise et genere des alertes, sans intervenir sur les paquets. Un IPS, place en coupure sur le flux, peut en plus bloquer ou abandonner activement un paquet identifie comme malveillant avant qu'il n'atteigne sa cible.

### 3. Que signifie "action": "allowed" dans un log EVE JSON ?

Cela signifie que Suricata a detecte l'activité correspondant a une signature et l'a journalisee, mais a laisse le paquet poursuivre son chemin sans le bloquer : c'est le comportement normal et attendu du mode IDS.

### 4. Pourquoi les mises a jour automatiques quotidiennes des règles sont-elles essentielles en production ?

De nouvelles menaces et de nouveaux indicateurs de compromission apparaissent en permanence. Sans mise a jour régulière des jeux de règles, Suricata continue de fonctionner avec une base de signatures obsolète et devient incapable de détecter les campagnes d'attaque recentes.